ASA AI

DOCUMENT D'INGÉNIERIE • SÉCURITÉ VOIP

Rapport d'audit Sécurité de l'IA

Agents IA, workflows et modèles LLM — Organisation Exemple SA (fictive)

Référence ASA-AUD-2026-EX01 • Version du rapport 1.0 • Confidentiel

Auteur : ASA AI — Auditeur principal (exemple)

Date du rapport : 01/10/2026 • Janvier à septembre 2026

ISO 19011:2018 • NIST SP 800-53A • ISO/IEC 42001:2023 • ISO/IEC 23894:2023 • ISO/IEC 27001:2022 • CSA AICM • NIST AI RMF 1.0 • NIST AI 600-1 • OWASP Top 10 LLM



Page laissée intentionnellement blanche

Sommaire

1. Synthèse pour la direction 5
1.1 Opinion d'ensemble 5
1.2 Indicateurs clés 5
1.3 Principaux risques 5
1.4 Recommandations prioritaires 5
2. Cadre de la mission 6
2.1 Identification de la mission 6
2.2 Parties prenantes 6
2.3 Calendrier 6
2.4 Objectifs 7
2.5 Périmètre et exclusions 7
3. Référentiels et critères d'audit 8
3.1 Référentiels retenus 8
3.2 Domaines évalués 8
4. Méthodologie 10
4.1 Principes d'audit (ISO 19011) 10
4.2 Méthodes de vérification (NIST SP 800-53A) 10
4.3 Échelle de cotation 10
4.4 Évaluation des risques 10
4.5 Entretiens et documents examinés 11
4.6 Hypothèses et limites 11
5. Résultats globaux 12
5.1 Synthèse chiffrée 12
5.2 Répartition des réponses et des risques 12
5.3 Conformité par domaine 12
5.4 Conformité par référentiel 13
5.5 Matrice des risques résiduels 13
6. Résultats détaillés par domaine 14
6.1 Gouvernance et organisation de l'IA 14
6.2 Inventaire des usages et Shadow AI 14
6.3 Modèles LLM et chaîne d'approvisionnement 15
6.4 Données et vie privée 16
6.5 Prompts, entrées / sorties et RAG 16
6.6 Agents IA et autonomie 17
6.7 Workflows IA et intégrations (MCP, API, A2A) 18
6.8 Tests, red teaming et évaluation 18
6.9 Surveillance, journalisation et incidents 19
6.10 Réglementation et conformité 20
7. Registre des risques et plan d'action 21
7.1 Registre des risques 21
7.2 Plan d'action 23
8. Conclusion 26

Sommaire (suite)

8.1 Conclusion de l'auditeur 26
8.2 Prochaines étapes 26

9. Validation et diffusion 27

9.1 Validation 27
9.2 Liste de diffusion 27

Annexes 28

Annexe A — Profil de l'organisation 28
Annexe B — Glossaire 28
Annexe C — Avertissement 28

1. Synthèse pour la direction

1.1 Opinion d'ensemble

> Le dispositif est défini et couvre une partie significative des exigences. Des écarts importants subsistent sur certains domaines. La mise en œuvre du plan d'action permettrait d'atteindre un niveau maîtrisé.

Questionnaire incomplet : 8 question(s) applicable(s) sans réponse sont exclues du calcul.

1.2 Indicateurs clés

CONFORMITÉ GLOBALE	COMPLÉTION	NIVEAU DE MATURITÉ	RISQUES CRITIQUES / ÉLEVÉS
58%	**92%**	**2 · Défini**	**12 / 15**

1.3 Principaux risques

ID	Question	Réponse	Risque	Niveau
AGT-03	Les droits des agents sont-ils limités au strict nécessaire pour chaque tâche ?	Non	20	**Critique**
AGT-04	Les actions à fort impact (paiement, suppression, envoi externe) exigent-elles une validation humaine ?	Non	20	**Critique**
WFL-01	Les serveurs MCP, API et outils connectés aux agents sont-ils inventoriés et approuvés ?	Ne sait pas	20	**Critique**
WFL-04	Les paramètres envoyés aux outils sont-ils validés avant exécution ?	Ne sait pas	20	**Critique**
AGT-10	Les objectifs et plans des agents sont-ils contrôlés pour détecter un détournement ?	Ne sait pas	20	**Critique**

1.4 Recommandations prioritaires

- Workflows IA et intégrations (MCP, API, A2A) (33%) : Inventorier et approuver les outils connectés, limiter les jetons et valider les paramètres envoyés aux outils.
- Surveillance, journalisation et incidents (47%) : Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.
- Agents IA et autonomie (50%) : Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.
- Tests, red teaming et évaluation (53%) : Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.

2. Cadre de la mission

2.1 Identification de la mission

Référence	ASA-AUD-2026-EX01
Type d'audit	Audit externe (tierce partie)
Version du rapport	1.0
Classification	Confidentiel
Date du rapport	01/10/2026
Langue	Français

2.2 Parties prenantes

Raison sociale	Organisation Exemple SA (fictive)
Secteur d'activité	Services financiers
Adresse	Paris, France
Identifiant (SIREN, n° TVA…)	Non renseigné
Effectif	850
Commanditaire (nom, fonction)	Responsable de la sécurité des systèmes d'information
Contact principal (nom, fonction, e-mail)	Responsable du programme IA

Cabinet d'audit	ASA AI
Auditeur principal (nom, fonction)	Auditeur principal (exemple)
Certifications de l'auditeur	ISO/IEC 42001 Lead Auditor, ISO/IEC 27001 Lead Auditor
Équipe d'audit et experts	1 auditeur principal, 1 expert sécurité de l'IA
Contact de l'auditeur	contact@asa-ai.fr

L'équipe d'audit déclare n'avoir aucun conflit d'intérêts avec le périmètre audité.

2.3 Calendrier

Réunion d'ouverture	14/09/2026
Début des travaux	14/09/2026
Fin des travaux	25/09/2026
Réunion de clôture	29/09/2026
Date du rapport	01/10/2026
Période couverte par l'audit	Janvier à septembre 2026

2.4 Objectifs

Évaluer le niveau de sécurité et de gouvernance des systèmes d'IA (agents, workflows, modèles de langage) au regard des référentiels retenus, identifier les écarts et les risques résiduels, et proposer un plan d'action priorisé.

2.5 Périmètre et exclusions

Direction des systèmes d'information du siège ; services de support client et assistant interne

Systèmes d'IA audités

- Assistant interne (RAG sur la base documentaire)
- Agent de support client (outils de ticketing et CRM)
- Assistant de code pour les développeurs

Exclusions

Filiales hors de France ; fonctions IA des logiciels bureautiques non activées

Profil de l'organisation : voir l'annexe A.

3. Référentiels et critères d'audit

3.1 Référentiels retenus

Référentiel	Objet
ISO 19011:2018	Lignes directrices pour l'audit des systèmes de management : principes, conduite de l'audit, compétences des auditeurs.
NIST SP 800-53A Rev. 5	Évaluation des contrôles de sécurité : méthodes examiner, interroger, tester.
ISO/IEC 42001:2023	Système de management de l'intelligence artificielle.
ISO/IEC 23894:2023	Lignes directrices pour le management du risque lié à l'IA.
ISO/IEC 27001:2022	Système de management de la sécurité de l'information.
CSA AI Controls Matrix (AICM)	Matrice de contrôles de sécurité de l'IA de la Cloud Security Alliance.
NIST AI RMF 1.0 (AI 100-1)	Cadre de gestion des risques de l'IA : Govern, Map, Measure, Manage.
NIST AI 600-1	Profil IA générative du NIST AI RMF.
OWASP Top 10 for LLM Applications 2025	Dix risques majeurs des applications à base de LLM.
OWASP Top 10 for Agentic Applications	Dix risques majeurs propres aux agents IA (ASI01 à ASI10).
MITRE ATLAS	Base de tactiques et techniques d'attaque contre les systèmes d'IA.
Règlement (UE) 2024/1689 — AI Act	Règlement européen sur l'intelligence artificielle.
Règlement (UE) 2016/679 — RGPD / GDPR	Protection des données personnelles.
ANSSI — Recommandations de sécurité pour un système d'IA générative (2024)	Recommandations de l'agence nationale française de la sécurité des systèmes d'information.

3.2 Domaines évalués

Domaine	Questions	Applicables	Principaux référentiels liés
Gouvernance et organisation de l'IA	12	12	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act
Inventaire des usages et Shadow AI	8	8	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Modèles LLM et chaîne d'approvisionnement	12	8	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Données et vie privée	12	10	OWASP LLM, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Prompts, entrées / sorties et RAG	12	12	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Agents IA et autonomie	14	14	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, AI Act, MITRE ATLAS
Workflows IA et intégrations (MCP, API, A2A)	12	12	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, MITRE ATLAS
Tests, red teaming et évaluation	10	10	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act, MITRE ATLAS
Surveillance, journalisation et incidents	12	11	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act

Domaine	Questions	Applicables	Principaux référentiels liés
Réglementation et conformité	10	6	OWASP LLM, OWASP ASI, CSA AICM, NIST AI RMF, ISO/IEC 42001, AI Act

Correspondances indicatives : elles orientent l'analyse et ne remplacent pas la lecture des textes officiels.

4. Méthodologie

4.1 Principes d'audit (ISO 19011)

- Intégrité : Travailler avec honnêteté, diligence et responsabilité.
- Présentation impartiale : Rapporter fidèlement les constats, y compris les désaccords.
- Conscience professionnelle : Exercer un jugement adapté à l'importance de la mission.
- Confidentialité : Protéger les informations obtenues pendant l'audit.
- Indépendance : Rester impartial et objectif vis-à-vis du périmètre audité.
- Approche fondée sur la preuve : Fonder les conclusions sur des preuves vérifiables.
- Approche fondée sur le risque : Concentrer l'effort sur ce qui compte le plus.

4.2 Méthodes de vérification (NIST SP 800-53A)

Méthode de vérification	Objet	Utilisée	Réponses
Examen documentaire	Examiner politiques, procédures, configurations, journaux.	Oui	40
Entretien	Interroger les responsables et les équipes.	Oui	42
Test technique	Tester le fonctionnement réel du contrôle.	Oui	23
Observation	Observer une activité ou un processus en cours.	Non	0

4.3 Échelle de cotation

Réponse	Signification
Oui	Contrôle en place, appliqué et prouvé
Partiel	Contrôle existant mais incomplet ou non appliqué partout
Non	Contrôle absent
Ne sait pas	Information non disponible : traité comme un écart
N.A.	Non applicable (profil ou justification)

Score	Oui = 100 % du poids, Partiel = 50 %, Non et Ne sait pas = 0. N.A. et questions non renseignées sont exclues.
Poids	1 utile • 2 important • 3 essentiel.
Risque	Impact (1-5) × probabilité résiduelle (1-5). Probabilité résiduelle : 1 si Oui, base - 2 si Partiel (minimum 1), base si Non ou Ne sait pas.
Niveau	Critique ≥ 15 • Élevé 10-14 • Moyen 5-9 • Faible < 5.
Maturité	0 Initial (< 20 %) • 1 Exploratoire (< 40 %) • 2 Défini (< 60 %) • 3 Maîtrisé (< 80 %) • 4 Optimisé (≥ 80 %).

4.4 Évaluation des risques

Chaque question porte un impact (1 à 5) et une probabilité de base (1 à 5). La probabilité résiduelle dépend de la réponse : 1 si Oui, base moins 2 si Partiel (minimum 1), base si Non ou Ne sait pas. Le risque résiduel est le produit de l'impact et de la probabilité résiduelle (1 à 25) : Critique à partir de 15, Élevé de 10 à 14, Moyen de 5 à 9, Faible en dessous de 5. Le score de conformité pondère chaque question par son poids (1 à 3) : Oui vaut 100 %, Partiel 50 %, Non et Ne sait pas 0 %.

4.5 Entretiens et documents examinés

Personnes interrogées

- RSSI (14/09)
- Responsable du programme IA (15/09)
- Responsable des développements (16/09)
- Responsable du SOC (17/09)
- Délégué à la protection des données (18/09)

Documents examinés

- Politique d'usage de l'IA v1.2
- Registre des systèmes d'IA
- Analyses de risques des 3 systèmes
- Contrats fournisseurs
- Configuration de la journalisation et du SIEM

Outils utilisés

- Jeu de tests d'injection de prompt, scripts de revue de configuration

Échantillonnage

- Les 3 systèmes d'IA du périmètre ; 20 actions d'agent échantillonnées par système

4.6 Hypothèses et limites

Tests techniques limités à l'environnement de préproduction.

Les constats reposent sur les informations, documents et démonstrations fournis pendant la période d'audit. L'audit procède par sondage : il ne garantit pas l'absence d'autres écarts. Les correspondances avec les référentiels sont indicatives et ne constituent pas une attestation de conformité.

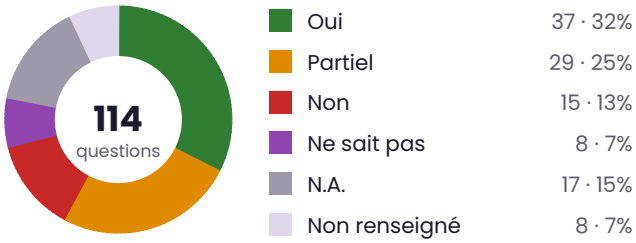
5. Résultats globaux

5.1 Synthèse chiffrée

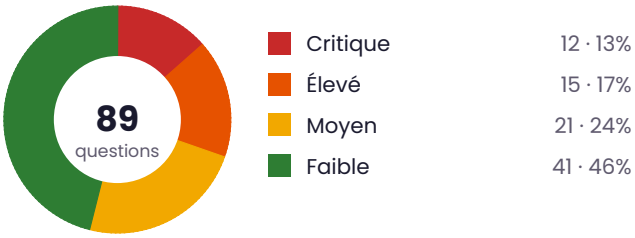
Domaine	Applicables	Répondues	Conformité	Écarts
Gouvernance et organisation de l'IA	12	12	73%	5
Inventaire des usages et Shadow AI	8	8	58%	5
Modèles LLM et chaîne d'approvisionnement	8	7	67%	4
Données et vie privée	10	8	63%	5
Prompts, entrées / sorties et RAG	12	12	54%	6
Agents IA et autonomie	14	13	50%	10
Workflows IA et intégrations (MCP, API, A2A)	12	10	33%	5
Tests, red teaming et évaluation	10	9	53%	6
Surveillance, journalisation et incidents	11	10	47%	6
Réglementation et conformité	6	6	100%	0
Total	103	95	58%	52

5.2 Répartition des réponses et des risques

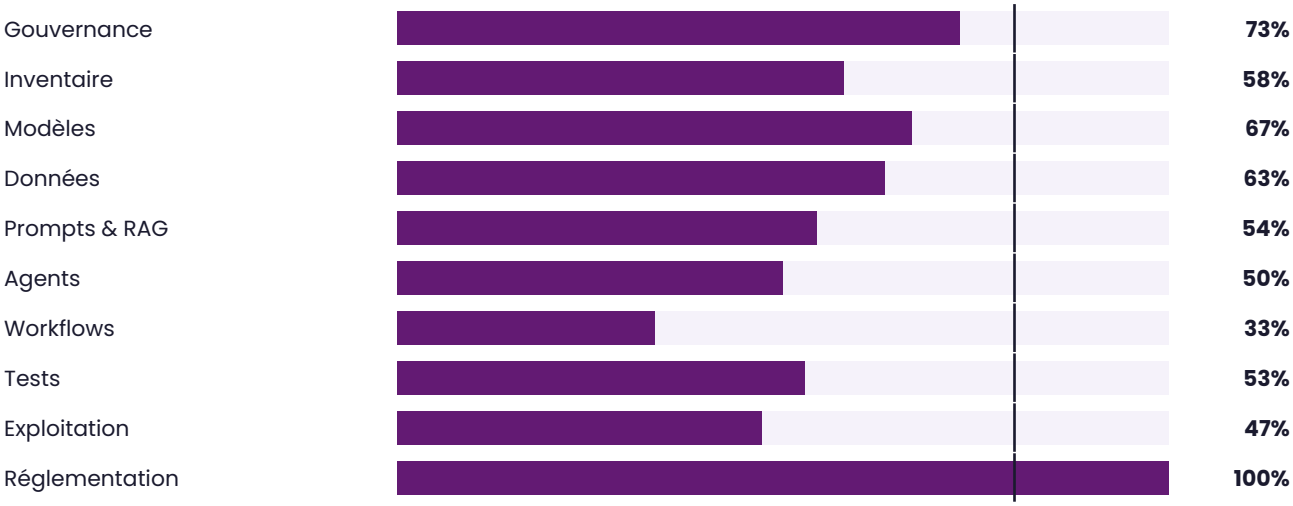
Répartition des réponses



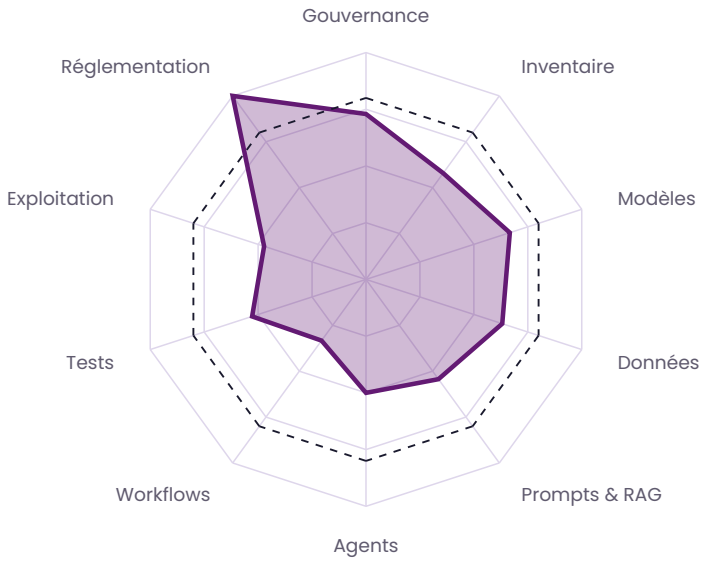
Risques résiduels par niveau



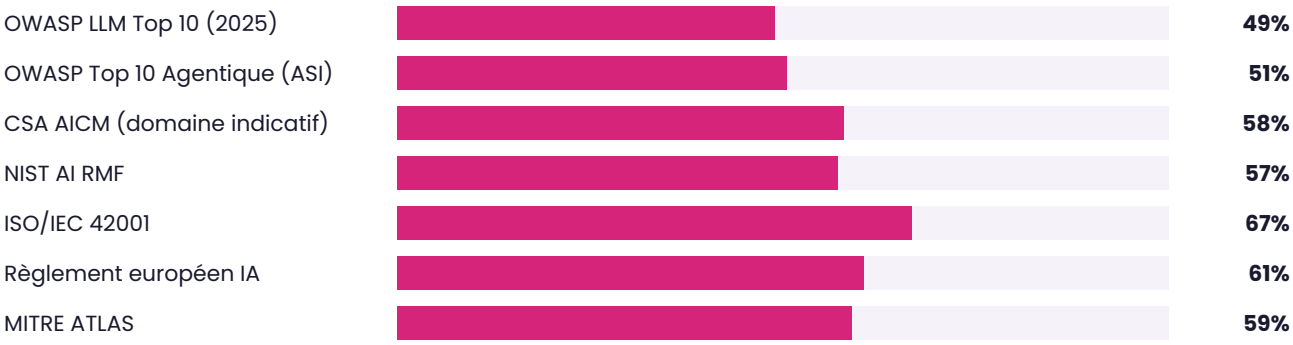
5.3 Conformité par domaine



Trait vertical : cible 80 %.



5.4 Conformité par référentiel



Correspondances indicatives : elles orientent l'analyse et ne remplacent pas la lecture des textes officiels.

5.5 Matrice des risques résiduels

Impact / Probabilité	1	2	3	4	5
5 Majeur	12	6	0	6	0
4 Fort	26	2	3	6	0
3 Modéré	15	5	1	6	0
2 Faible	0	0	0	1	0
1 Mineur	0	0	0	0	0

Lignes : impact • colonnes : probabilité résiduelle • nombre de questions par case.

6. Résultats détaillés par domaine

6.1 Gouvernance et organisation de l'IA

Conformité 73% • 12 applicables • 5 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
GOV-01	Une politique d'usage de l'IA est-elle formalisée, validée par la direction et diffusée ?	Partiel	Examen documentaire	8 Moyen	
GOV-02	Un responsable de la sécurité et de la gouvernance de l'IA est-il nommé ?	Partiel	Entretien	4 Faible	
GOV-03	Chaque système d'IA a-t-il un propriétaire métier identifié et responsable ?	Oui	Test technique	3 Faible	
GOV-04	Une analyse de risques est-elle réalisée avant toute mise en service d'un système d'IA ?	Oui	Examen documentaire	5 Moyen	
GOV-05	Une analyse d'impact sur les personnes et la société est-elle conduite pour les usages sensibles ?	Oui	Entretien	4 Faible	
GOV-06	Les niveaux d'autonomie autorisés pour l'IA sont-ils définis selon le niveau de risque ?	Partiel	Examen documentaire	10 Élevé	
GOV-07	Les collaborateurs sont-ils formés aux risques et au bon usage de l'IA ?	Oui	Entretien	3 Faible	
GOV-08	Les fournisseurs d'IA sont-ils évalués (sécurité, localisation des données, contrats) avant contractualisation ?	N.A.	Test technique	—	
GOV-09	La sécurité de l'IA est-elle intégrée au même processus d'incident que la cybersécurité ?	Partiel	Examen documentaire	4 Faible	
GOV-10	Des indicateurs de risque IA sont-ils suivis et présentés à la direction ?	Oui	Entretien	3 Faible	
GOV-11	Les contrats d'assurance ont-ils été revus au regard des exclusions liées à l'IA ?	Oui	Examen documentaire	4 Faible	
GOV-12	Un processus de retrait (décommissionnement) des systèmes d'IA existe-t-il ?	Ne sait pas	Entretien	9 Moyen	

6.2 Inventaire des usages et Shadow AI

Conformité 58% • 8 applicables • 5 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
INV-01	Un registre central de tous les systèmes, modèles et agents d'IA est-il tenu à jour ?	Non	Test technique	16 Critique	
INV-02	L'usage d'outils d'IA non autorisés (Shadow AI) est-il détecté ?	Oui	Examen documentaire	4 Faible	
INV-03	Une liste d'outils d'IA approuvés est-elle publiée et proposée comme alternative ?	Partiel	Entretien	6 Moyen	
INV-04	Les autorisations accordées par les employés à des applications d'IA tierces (OAuth) sont-elles contrôlées ?	Oui	Examen documentaire	5 Moyen	
INV-05	Les fonctions d'IA intégrées dans les logiciels existants (SaaS, bureautique) sont-elles recensées ?	Non	Entretien	12 Élevé	

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
INV-06	Chaque système d'IA est-il classé selon son niveau de risque ?	Oui	Test technique	4 Faible	
INV-07	Le niveau d'adoption de l'IA (de l'assistant intégré aux agents multi-organisations) est-il connu ?	Non	Examen documentaire	12 Élevé	
INV-08	Les composants de chaque système (modèles, bibliothèques, prompts, outils) sont-ils inventoriés (AI SBOM) ?	Partiel	Entretien	4 Faible	

6.3 Modèles LLM et chaîne d'approvisionnement

Conformité 67% • 8 applicables • 4 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
MOD-01	Les modèles utilisés proviennent-ils de sources vérifiées et approuvées ?	Oui	Examen documentaire	5 Moyen	
MOD-02	Les fichiers de modèles sont-ils chargés dans des formats sûrs (safetensors, GGUF) plutôt que pickle ?	N.A.	Entretien	—	
MOD-03	Un processus d'admission valide chaque nouveau modèle avant sa mise en production ?	N.A.	—	—	
MOD-04	Les jeux de données d'entraînement ou d'ajustement sont-ils contrôlés contre l'empoisonnement ?	N.A.	—	—	
MOD-05	Les poids des modèles et les points d'accès d'inférence sont-ils protégés contre le vol ?	N.A.	Entretien	—	
MOD-06	Les versions des modèles sont-elles figées et tout changement de version testé ?	Partiel	Examen documentaire	6 Moyen	
MOD-07	Le choix entre modèle hébergé localement et service cloud est-il justifié par la sensibilité des données ?	Non renseigné	—	—	
MOD-08	Les limites connues des modèles (hallucinations, biais, domaines faibles) sont-elles documentées ?	Oui	Test technique	3 Faible	
MOD-09	Les modèles sont-ils évalués sur leur robustesse (attaques adverses, contournement) ?	Partiel	Examen documentaire	4 Faible	
MOD-10	La consommation de ressources (jetons, GPU, coût) est-elle plafonnée ?	Non	Entretien	12 Élevé	
MOD-11	Le modèle adapté à chaque tâche est-il choisi (petit modèle quand c'est suffisant) ?	Non	Examen documentaire	8 Moyen	
MOD-12	Les extensions, plugins et « skills » chargés par les modèles sont-ils vérifiés ?	Oui	Entretien	5 Moyen	

6.4 Données et vie privée

Conformité 63% • 10 applicables • 5 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
DAT-01	Les données envoyées aux modèles sont-elles classées (publique, interne, confidentielle) ?	Oui	Test technique	4 Faible	
DAT-02	Un contrôle empêche-t-il l'envoi de données sensibles vers des services d'IA externes (DLP) ?	Non renseigné	—	—	
DAT-03	Le principe de minimisation est-il appliqué aux données personnelles traitées par l'IA ?	Partiel	Entretien	4 Faible	
DAT-04	Une analyse d'impact (AIPD/DPIA) est-elle réalisée pour les traitements d'IA à risque ?	Oui	Examen documentaire	4 Faible	
DAT-05	Les contrats garantissent-ils que le fournisseur n'utilise pas vos données pour entraîner ses modèles ?	Non	Entretien	16 Critique	
DAT-06	Les durées de conservation des prompts, réponses et journaux d'IA sont-elles définies ?	Partiel	Test technique	6 Moyen	
DAT-07	Les personnes sont-elles informées lorsque leurs données sont traitées par une IA ?	Oui	Examen documentaire	3 Faible	
DAT-08	Les données d'entraînement sont-elles documentées (origine, licences, qualité, biais) ?	N.A.	Entretien	—	
DAT-09	Les données traitées par l'IA sont-elles chiffrées en transit et au repos ?	Partiel	Examen documentaire	4 Faible	
DAT-10	Les techniques de protection de la vie privée sont-elles envisagées (anonymisation, données synthétiques, confidentialité différentielle) ?	Partiel	Entretien	3 Faible	
DAT-11	Les risques de fuite de données par le modèle (mémorisation, inférence d'appartenance) sont-ils évalués ?	N.A.	Test technique	—	
DAT-12	Le transfert de données hors de l'UE par les services d'IA est-il identifié et encadré ?	Non renseigné	—	—	

6.5 Prompts, entrées / sorties et RAG

Conformité 54% • 12 applicables • 6 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
PRM-01	Les entrées des utilisateurs sont-elles filtrées contre l'injection de prompt ?	Oui	Entretien	5 Moyen	
PRM-02	Les contenus externes lus par l'IA (pages web, e-mails, documents) sont-ils traités comme non fiables ?	N.A.	Examen documentaire	—	
PRM-03	Les sorties de l'IA sont-elles validées avant d'être exécutées ou affichées ?	Partiel	Entretien	10 Élevé	
PRM-04	Le prompt système ne contient-il aucun secret (mot de passe, clé, règle de sécurité critique) ?	Oui	Test technique	4 Faible	
PRM-05	Les réponses sont-elles filtrées pour éviter la divulgation de données sensibles ?	Non	Examen documentaire	16 Critique	

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
PRM-06	Les droits d'accès aux documents sont-ils respectés dans les recherches RAG ?	Partiel	Entretien	10 Élevé	
PRM-07	Les documents ajoutés à la base RAG sont-ils contrôlés (origine, contenu malveillant) ?	Ne sait pas	Examen documentaire	16 Critique	
PRM-08	Les bases vectorielles sont-elles cloisonnées par client ou par niveau de sensibilité ?	Non	Entretien	12 Élevé	
PRM-09	Les réponses citent-elles leurs sources pour permettre la vérification ?	Oui	Test technique	3 Faible	
PRM-10	Les prompts système et modèles de prompts sont-ils versionnés et revus ?	Oui	Examen documentaire	3 Faible	
PRM-11	Les utilisateurs sont-ils avertis que les réponses de l'IA peuvent être erronées ?	Partiel	Entretien	6 Moyen	
PRM-12	La longueur et le volume des requêtes sont-ils limités ?	Oui	Examen documentaire	3 Faible	

6.6 Agents IA et autonomie

Conformité 50% • 14 applicables • 10 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
AGT-01	Chaque agent dispose-t-il de sa propre identité, distincte des comptes humains et partagés ?	Oui	Entretien	5 Moyen	
AGT-02	Les agents utilisent-ils des identifiants de courte durée plutôt que des clés permanentes ?	Partiel	Test technique	10 Élevé	
AGT-03	Les droits des agents sont-ils limités au strict nécessaire pour chaque tâche ?	Non	Examen documentaire	20 Critique	
AGT-04	Les actions à fort impact (paiement, suppression, envoi externe) exigent-elles une validation humaine ?	Non	Entretien	20 Critique	
AGT-05	Un arrêt d'urgence permet-il de stopper un agent en quelques secondes ?	Non renseigné	Test technique	—	Révocation manuelle des jetons, testée en mars
AGT-06	Chaque action d'un agent porte-t-elle aussi l'identité de la personne à l'origine de la demande ?	Partiel	Entretien	4 Faible	
AGT-07	Le code généré ou exécuté par les agents tourne-t-il dans un environnement isolé (bac à sable) ?	Partiel	Test technique	10 Élevé	
AGT-08	Les protections de l'agent sont-elles hors de sa portée (il ne peut pas modifier son propre cadre) ?	Partiel	Examen documentaire	5 Moyen	
AGT-09	La mémoire des agents est-elle protégée contre l'empoisonnement et cloisonnée par utilisateur ?	Partiel	Entretien	4 Faible	
AGT-10	Les objectifs et plans des agents sont-ils contrôlés pour détecter un détournement ?	Ne sait pas	Examen documentaire	20 Critique	
AGT-11	Les communications entre agents sont-elles authentifiées et chiffrées ?	Partiel	Entretien	4 Faible	
AGT-12	Des limites empêchent-elles les défaillances en cascade (boucles, budgets, nombre d'étapes) ?	Partiel	Test technique	4 Faible	

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
AGT-13	Les agents créés pour une tâche sont-ils supprimés avec leurs accès une fois la tâche terminée ?	Oui	Examen documentaire	4 Faible	
AGT-14	Les agents de code ont-ils des garde-fous spécifiques (pas de déploiement direct en production, revue) ?	Oui	Entretien	5 Moyen	

6.7 Workflows IA et intégrations (MCP, API, A2A)

Conformité 33% • 12 applicables • 5 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
WFL-01	Les serveurs MCP, API et outils connectés aux agents sont-ils inventoriés et approuvés ?	Ne sait pas	Examen documentaire	20 Critique	
WFL-02	Les jetons d'accès aux outils sont-ils limités à une ressource et à une durée (OAuth 2.1) ?	Oui	Entretien	5 Moyen	
WFL-03	Les descriptions et définitions d'outils sont-elles protégées contre la modification malveillante ?	Oui	Test technique	5 Moyen	
WFL-04	Les paramètres envoyés aux outils sont-ils validés avant exécution ?	Ne sait pas	Examen documentaire	20 Critique	
WFL-05	Les serveurs MCP locaux ou tiers tournent-ils avec des privilèges réduits ?	N.A.	Entretien	—	
WFL-06	Les annuaires et fiches d'agents (découverte A2A) sont-ils vérifiés avant de faire confiance à un agent tiers ?	Non renseigné	—	—	
WFL-07	Les workflows automatisés (no-code, low-code) utilisant l'IA sont-ils revus par la sécurité ?	Non renseigné	—	—	
WFL-08	Les secrets utilisés par les workflows sont-ils stockés dans un coffre-fort et non dans le code ou les prompts ?	N.A.	Test technique	—	
WFL-09	Les agents dans les chaînes CI/CD sont-ils protégés contre les contenus externes non fiables (tickets, demandes de fusion) ?	Ne sait pas	Examen documentaire	20 Critique	
WFL-10	Les mises à jour des serveurs MCP et outils sont-elles contrôlées (version figée, vérification) ?	Non	Entretien	12 Élevé	
WFL-11	Les flux de données entre l'IA et les systèmes métiers sont-ils cartographiés ?	Non	Examen documentaire	12 Élevé	
WFL-12	Un mode dégradé est-il prévu si le modèle ou un outil devient indisponible ?	Oui	Entretien	3 Faible	

6.8 Tests, red teaming et évaluation

Conformité 53% • 10 applicables • 6 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
TST-01	Des tests d'attaque (red teaming) sont-ils réalisés avant la mise en production ?	Partiel	Test technique	10 Élevé	
TST-02	Les tests couvrent-ils les dix risques du Top 10 agentique de l'OWASP ?	Partiel	Examen documentaire	8 Moyen	

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
TST-03	Des jeux d'évaluation automatisés sont-ils exécutés à chaque changement de modèle, de prompt ou d'outil ?	Oui	Entretien	4 Faible	
TST-04	La qualité des réponses (exactitude, hallucinations) est-elle mesurée avec des indicateurs ?	Partiel	Examen documentaire	6 Moyen	
TST-05	Les biais et l'équité des résultats sont-ils évalués pour les usages qui concernent des personnes ?	Non	Entretien	12 Élevé	
TST-06	Les applications générées par IA (« vibe coding ») passent-elles une revue de sécurité ?	Ne sait pas	Test technique	16 Critique	
TST-07	Les vulnérabilités des composants d'IA sont-elles suivies et corrigées (veille CVE) ?	Oui	Examen documentaire	4 Faible	
TST-08	Les tests sont-ils répétés régulièrement après la mise en production ?	Non renseigné	—	—	
TST-09	Un audit indépendant des systèmes d'IA critiques est-il prévu ?	Oui	Examen documentaire	3 Faible	
TST-10	L'arrêt d'urgence et la procédure d'incident IA sont-ils testés par des exercices ?	Partiel	Entretien	4 Faible	

6.9 Surveillance, journalisation et incidents

Conformité 47% • 11 applicables • 6 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
OPS-01	Chaque interaction et chaque action de l'IA sont-elles journalisées ?	Non	Test technique	16 Critique	
OPS-02	Les journaux sont-ils protégés contre la modification (infalsifiables) ?	Partiel	Examen documentaire	4 Faible	
OPS-03	Les journaux d'IA sont-ils envoyés au SIEM et analysés par le SOC ?	Oui	Entretien	4 Faible	
OPS-04	Des alertes détectent-elles les comportements anormaux des agents ou des modèles ?	Non renseigné	—	—	
OPS-05	Une procédure de réponse aux incidents spécifique à l'IA existe-t-elle ?	Partiel	Entretien	5 Moyen	
OPS-06	Peut-on notifier un incident dans les délais réglementaires (4 h DORA, 24 h NIS2) ?	N.A.	Test technique	—	
OPS-07	Les performances et la qualité des systèmes d'IA sont-elles surveillées en continu ?	Non	Examen documentaire	12 Élevé	
OPS-08	Un retour arrière vers une version antérieure (modèle, prompt, outil) est-il possible rapidement ?	Partiel	Entretien	4 Faible	
OPS-09	Les utilisateurs peuvent-ils signaler facilement une réponse ou une action problématique ?	Oui	Examen documentaire	3 Faible	
OPS-10	Les coûts et la consommation de l'IA sont-ils suivis pour détecter les abus ?	Ne sait pas	Entretien	12 Élevé	
OPS-11	Les journaux permettent-ils de reconstituer précisément un incident ?	N.A.	Test technique	—	
OPS-12	Un plan de continuité couvre-t-il l'indisponibilité d'un fournisseur d'IA ?	Oui	Examen documentaire	3 Faible	

6.10 Réglementation et conformité

Conformité 100% • 6 applicables • 0 écarts

ID	Question	Réponse	Méthode de vérification	Risque	Preuve / constat
REG-01	Les obligations du règlement européen sur l'IA applicables à l'organisation sont-elles identifiées ?	**Oui**	Entretien	4 Faible	
REG-02	Aucun usage interdit par le règlement européen sur l'IA n'est pratiqué ?	**Oui**	Examen documentaire	5 Moyen	
REG-03	La documentation technique des systèmes à haut risque est-elle tenue à jour ?	**N.A.**	Entretien	—	
REG-04	Une surveillance humaine effective est-elle organisée pour les systèmes à haut risque ?	**N.A.**	Test technique	—	
REG-05	Un plan de surveillance après mise sur le marché est-il en place ?	**N.A.**	Examen documentaire	—	
REG-06	Les utilisateurs sont-ils informés qu'ils interagissent avec une IA ou un contenu généré ?	**N.A.**	Entretien	—	
REG-07	Les exigences RGPD sont-elles intégrées aux projets d'IA dès la conception ?	**Oui**	Examen documentaire	4 Faible	
REG-08	Les exigences sectorielles (DORA, NIS2) sont-elles appliquées aux systèmes d'IA ?	**N.A.**	Entretien	—	
REG-09	L'organisation vise-t-elle ou suit-elle un système de management de l'IA (ISO/IEC 42001) ?	**Oui**	Test technique	3 Faible	
REG-10	Les correspondances entre contrôles internes et référentiels (NIST, ISO, AICM) sont-elles maintenues ?	**Oui**	Examen documentaire	3 Faible	

7. Registre des risques et plan d'action

7.1 Registre des risques

ID	Domaine	Question	Réponse	Risque	Niveau
AGT-03	Agents	Les droits des agents sont-ils limités au strict nécessaire pour chaque tâche ?	Non	20	**Critique**
AGT-04	Agents	Les actions à fort impact (paiement, suppression, envoi externe) exigent-elles une validation humaine ?	Non	20	**Critique**
WFL-01	Workflows	Les serveurs MCP, API et outils connectés aux agents sont-ils inventoriés et approuvés ?	Ne sait pas	20	**Critique**
WFL-04	Workflows	Les paramètres envoyés aux outils sont-ils validés avant exécution ?	Ne sait pas	20	**Critique**
AGT-10	Agents	Les objectifs et plans des agents sont-ils contrôlés pour détecter un détournement ?	Ne sait pas	20	**Critique**
WFL-09	Workflows	Les agents dans les chaînes CI/CD sont-ils protégés contre les contenus externes non fiables (tickets, demandes de fusion) ?	Ne sait pas	20	**Critique**
INV-01	Inventaire	Un registre central de tous les systèmes, modèles et agents d'IA est-il tenu à jour ?	Non	16	**Critique**
DAT-05	Données	Les contrats garantissent-ils que le fournisseur n'utilise pas vos données pour entraîner ses modèles ?	Non	16	**Critique**
PRM-05	Prompts & RAG	Les réponses sont-elles filtrées pour éviter la divulgation de données sensibles ?	Non	16	**Critique**
OPS-01	Exploitation	Chaque interaction et chaque action de l'IA sont-elles journalisées ?	Non	16	**Critique**
PRM-07	Prompts & RAG	Les documents ajoutés à la base RAG sont-ils contrôlés (origine, contenu malveillant) ?	Ne sait pas	16	**Critique**
TST-06	Tests	Les applications générées par IA (« vibe coding ») passent-elles une revue de sécurité ?	Ne sait pas	16	**Critique**
PRM-08	Prompts & RAG	Les bases vectorielles sont-elles cloisonnées par client ou par niveau de sensibilité ?	Non	12	**Élevé**
WFL-10	Workflows	Les mises à jour des serveurs MCP et outils sont-elles contrôlées (version figée, vérification) ?	Non	12	**Élevé**
TST-05	Tests	Les biais et l'équité des résultats sont-ils évalués pour les usages qui concernent des personnes ?	Non	12	**Élevé**
INV-05	Inventaire	Les fonctions d'IA intégrées dans les logiciels existants (SaaS, bureautique) sont-elles recensées ?	Non	12	**Élevé**
MOD-10	Modèles	La consommation de ressources (jetons, GPU, coût) est-elle plafonnée ?	Non	12	**Élevé**
WFL-11	Workflows	Les flux de données entre l'IA et les systèmes métiers sont-ils cartographiés ?	Non	12	**Élevé**
OPS-07	Exploitation	Les performances et la qualité des systèmes d'IA sont-elles surveillées en continu ?	Non	12	**Élevé**
INV-07	Inventaire	Le niveau d'adoption de l'IA (de l'assistant intégré aux agents multi-organisations) est-il connu ?	Non	12	**Élevé**
OPS-10	Exploitation	Les coûts et la consommation de l'IA sont-ils suivis pour détecter les abus ?	Ne sait pas	12	**Élevé**
GOV-06	Gouvernance	Les niveaux d'autonomie autorisés pour l'IA sont-ils définis selon le niveau de risque ?	Partiel	10	**Élevé**

ID	Domaine	Question	Réponse	Risque	Niveau
PRM-03	Prompts & RAG	Les sorties de l'IA sont-elles validées avant d'être exécutées ou affichées ?	Partiel	10	Élevé
PRM-06	Prompts & RAG	Les droits d'accès aux documents sont-ils respectés dans les recherches RAG ?	Partiel	10	Élevé
AGT-02	Agents	Les agents utilisent-ils des identifiants de courte durée plutôt que des clés permanentes ?	Partiel	10	Élevé
AGT-07	Agents	Le code généré ou exécuté par les agents tourne-t-il dans un environnement isolé (bac à sable) ?	Partiel	10	Élevé
TST-01	Tests	Des tests d'attaque (red teaming) sont-ils réalisés avant la mise en production ?	Partiel	10	Élevé
GOV-12	Gouvernance	Un processus de retrait (décommissionnement) des systèmes d'IA existe-t-il ?	Ne sait pas	9	Moyen
GOV-01	Gouvernance	Une politique d'usage de l'IA est-elle formalisée, validée par la direction et diffusée ?	Partiel	8	Moyen
TST-02	Tests	Les tests couvrent-ils les dix risques du Top 10 agentique de l'OWASP ?	Partiel	8	Moyen
MOD-11	Modèles	Le modèle adapté à chaque tâche est-il choisi (petit modèle quand c'est suffisant) ?	Non	8	Moyen
INV-03	Inventaire	Une liste d'outils d'IA approuvés est-elle publiée et proposée comme alternative ?	Partiel	6	Moyen
MOD-06	Modèles	Les versions des modèles sont-elles figées et tout changement de version testé ?	Partiel	6	Moyen
DAT-06	Données	Les durées de conservation des prompts, réponses et journaux d'IA sont-elles définies ?	Partiel	6	Moyen
TST-04	Tests	La qualité des réponses (exactitude, hallucinations) est-elle mesurée avec des indicateurs ?	Partiel	6	Moyen
PRM-11	Prompts & RAG	Les utilisateurs sont-ils avertis que les réponses de l'IA peuvent être erronées ?	Partiel	6	Moyen
AGT-08	Agents	Les protections de l'agent sont-elles hors de sa portée (il ne peut pas modifier son propre cadre) ?	Partiel	5	Moyen
OPS-05	Exploitation	Une procédure de réponse aux incidents spécifique à l'IA existe-t-elle ?	Partiel	5	Moyen
GOV-02	Gouvernance	Un responsable de la sécurité et de la gouvernance de l'IA est-il nommé ?	Partiel	4	Faible
DAT-03	Données	Le principe de minimisation est-il appliqué aux données personnelles traitées par l'IA ?	Partiel	4	Faible
GOV-09	Gouvernance	La sécurité de l'IA est-elle intégrée au même processus d'incident que la cybersécurité ?	Partiel	4	Faible
INV-08	Inventaire	Les composants de chaque système (modèles, bibliothèques, prompts, outils) sont-ils inventoriés (AI SBOM) ?	Partiel	4	Faible
MOD-09	Modèles	Les modèles sont-ils évalués sur leur robustesse (attaques adverses, contournement) ?	Partiel	4	Faible
DAT-09	Données	Les données traitées par l'IA sont-elles chiffrées en transit et au repos ?	Partiel	4	Faible
AGT-06	Agents	Chaque action d'un agent porte-t-elle aussi l'identité de la personne à l'origine de la demande ?	Partiel	4	Faible
AGT-09	Agents	La mémoire des agents est-elle protégée contre l'empoisonnement et cloisonnée par utilisateur ?	Partiel	4	Faible
AGT-11	Agents	Les communications entre agents sont-elles authentifiées et chiffrées ?	Partiel	4	Faible

ID	Domaine	Question	Réponse	Risque	Niveau
AGT-12	Agents	Des limites empêchent-elles les défaillances en cascade (boucles, budgets, nombre d'étapes) ?	Partiel	4	Faible
TST-10	Tests	L'arrêt d'urgence et la procédure d'incident IA sont-ils testés par des exercices ?	Partiel	4	Faible
OPS-02	Exploitation	Les journaux sont-ils protégés contre la modification (infalsifiables) ?	Partiel	4	Faible
OPS-08	Exploitation	Un retour arrière vers une version antérieure (modèle, prompt, outil) est-il possible rapidement ?	Partiel	4	Faible
DAT-10	Données	Les techniques de protection de la vie privée sont-elles envisagées (anonymisation, données synthétiques, confidentialité différentielle) ?	Partiel	3	Faible

7.2 Plan d'action

Priorités : P1 = risque critique, à traiter sous 3 mois ; P2 = élevé, sous 6 mois ; P3 = moyen, sous 12 mois ; P4 = faible, amélioration continue.

ID	Action	Responsable	Échéance	Priorité
AGT-03	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P1
AGT-04	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P1
WFL-01	À définir — Inventorier et approuver les outils connectés, limiter les jetons et valider les paramètres envoyés aux outils.	À définir	À définir	P1
WFL-04	À définir — Inventorier et approuver les outils connectés, limiter les jetons et valider les paramètres envoyés aux outils.	À définir	À définir	P1
AGT-10	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P1
WFL-09	À définir — Inventorier et approuver les outils connectés, limiter les jetons et valider les paramètres envoyés aux outils.	À définir	À définir	P1
INV-01	À définir — Constituer un registre central des systèmes et agents d'IA et détecter l'usage non autorisé.	À définir	À définir	P1
DAT-05	À définir — Classer les données, empêcher les fuites vers les services externes et appliquer le RGPD dès la conception.	À définir	À définir	P1
PRM-05	À définir — Déployer des garde-fous en entrée et en sortie contre l'injection de prompt et la divulgation de données.	À définir	À définir	P1
OPS-01	À définir — Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.	À définir	À définir	P1
PRM-07	À définir — Déployer des garde-fous en entrée et en sortie contre l'injection de prompt et la divulgation de données.	À définir	À définir	P1
TST-06	À définir — Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.	À définir	À définir	P1
PRM-08	À définir — Déployer des garde-fous en entrée et en sortie contre l'injection de prompt et la divulgation de données.	À définir	À définir	P2
WFL-10	À définir — Inventorier et approuver les outils connectés, limiter les jetons et valider les paramètres envoyés aux outils.	À définir	À définir	P2
TST-05	À définir — Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.	À définir	À définir	P2
INV-05	À définir — Constituer un registre central des systèmes et agents d'IA et détecter l'usage non autorisé.	À définir	À définir	P2

ID	Action	Responsable	Échéance	Priorité
MOD-10	À définir — Encadrer la provenance, l'admission et la robustesse des modèles et de leurs extensions.	À définir	À définir	P2
WFL-11	À définir — Inventorier et approuver les outils connectés, limiter les jetons et valider les paramètres envoyés aux outils.	À définir	À définir	P2
OPS-07	À définir — Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.	À définir	À définir	P2
INV-07	À définir — Constituer un registre central des systèmes et agents d'IA et détecter l'usage non autorisé.	À définir	À définir	P2
OPS-10	À définir — Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.	À définir	À définir	P2
GOV-06	À définir — Formaliser la politique IA, nommer les responsables et intégrer l'analyse de risques à chaque mise en service.	À définir	À définir	P2
PRM-03	À définir — Déployer des garde-fous en entrée et en sortie contre l'injection de prompt et la divulgation de données.	À définir	À définir	P2
PRM-06	À définir — Déployer des garde-fous en entrée et en sortie contre l'injection de prompt et la divulgation de données.	À définir	À définir	P2
AGT-02	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P2
AGT-07	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P2
TST-01	À définir — Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.	À définir	À définir	P2
GOV-12	À définir — Formaliser la politique IA, nommer les responsables et intégrer l'analyse de risques à chaque mise en service.	À définir	À définir	P3
GOV-01	À définir — Formaliser la politique IA, nommer les responsables et intégrer l'analyse de risques à chaque mise en service.	À définir	À définir	P3
TST-02	À définir — Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.	À définir	À définir	P3
MOD-11	À définir — Encadrer la provenance, l'admission et la robustesse des modèles et de leurs extensions.	À définir	À définir	P3
INV-03	À définir — Constituer un registre central des systèmes et agents d'IA et détecter l'usage non autorisé.	À définir	À définir	P3
MOD-06	À définir — Encadrer la provenance, l'admission et la robustesse des modèles et de leurs extensions.	À définir	À définir	P3
DAT-06	À définir — Classer les données, empêcher les fuites vers les services externes et appliquer le RGPD dès la conception.	À définir	À définir	P3
TST-04	À définir — Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.	À définir	À définir	P3
PRM-11	À définir — Déployer des garde-fous en entrée et en sortie contre l'injection de prompt et la divulgation de données.	À définir	À définir	P3
AGT-08	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P3
OPS-05	À définir — Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.	À définir	À définir	P3
GOV-02	À définir — Formaliser la politique IA, nommer les responsables et intégrer l'analyse de risques à chaque mise en service.	À définir	À définir	P4
DAT-03	À définir — Classer les données, empêcher les fuites vers les services externes et appliquer le RGPD dès la conception.	À définir	À définir	P4

ID	Action	Responsable	Échéance	Priorité
GOV-09	À définir — Formaliser la politique IA, nommer les responsables et intégrer l'analyse de risques à chaque mise en service.	À définir	À définir	P4
INV-08	À définir — Constituer un registre central des systèmes et agents d'IA et détecter l'usage non autorisé.	À définir	À définir	P4
MOD-09	À définir — Encadrer la provenance, l'admission et la robustesse des modèles et de leurs extensions.	À définir	À définir	P4
DAT-09	À définir — Classer les données, empêcher les fuites vers les services externes et appliquer le RGPD dès la conception.	À définir	À définir	P4
AGT-06	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P4
AGT-09	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P4
AGT-11	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P4
AGT-12	À définir — Donner une identité propre aux agents, limiter leurs droits, isoler leur exécution et prévoir un arrêt d'urgence.	À définir	À définir	P4
TST-10	À définir — Organiser des tests d'attaque réguliers couvrant les risques OWASP et des évaluations automatisées.	À définir	À définir	P4
OPS-02	À définir — Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.	À définir	À définir	P4
OPS-08	À définir — Journaliser chaque action de l'IA de manière infalsifiable, l'envoyer au SOC et préparer la réponse aux incidents.	À définir	À définir	P4
DAT-10	À définir — Classer les données, empêcher les fuites vers les services externes et appliquer le RGPD dès la conception.	À définir	À définir	P4

8. Conclusion

8.1 Conclusion de l'auditeur

> Le dispositif est défini et couvre une partie significative des exigences. Des écarts importants subsistent sur certains domaines. La mise en œuvre du plan d'action permettrait d'atteindre un niveau maîtrisé.

Conformité globale : 58% • Maturité : 2 — Défini • Critique 12 • Élevé 15 • Moyen 21 • Faible 41

8.2 Prochaines étapes

- Valider le plan d'action avec la direction et désigner un responsable par action.
- Traiter les actions P1 dans un délai de trois mois et suivre leur avancement mensuellement.
- Conserver les preuves de mise en œuvre pour la prochaine revue.
- Réaliser un audit de suivi dans un délai de douze mois, ou après tout changement majeur des systèmes d'IA.

9. Validation et diffusion

9.1 Validation

Rôle	Nom et fonction	Date	Signature
Auditeur principal	Auditeur principal (exemple)		
Représentant de l'entité auditée	Responsable de la sécurité des systèmes d'information		

9.2 Liste de diffusion

Ce rapport est classé « Confidentiel ». Sa diffusion est limitée aux destinataires suivants :

- RSSI
- DSI
- responsable du programme IA
- DPO

Annexes

Annexe A — Profil de l'organisation

Question de profil	Réponse
Utilisez-vous (ou prévoyez-vous) des agents IA capables d'agir : appeler des outils, des API, exécuter du code ?	Oui
Vos agents ou workflows IA se connectent-ils à des outils externes (MCP, API tierces, A2A, plugins) ?	Oui
Utilisez-vous des bases documentaires interrogées par l'IA (RAG, bases vectorielles) ?	Oui
Hébergez-vous, entraînez-vous ou ajustez-vous vos propres modèles ?	Non
Vos systèmes d'IA traitent-ils des données personnelles ?	Oui
Un de vos systèmes est-il à haut risque (règlement européen sur l'IA) ou soumis à DORA / NIS2 ?	Non

Annexe B — Glossaire

Agent IA	Système d'IA qui planifie et agit avec des outils pour atteindre un objectif.
AI SBOM	Inventaire des composants d'un système d'IA et de leur origine.
Arrêt d'urgence	Mécanisme qui stoppe immédiatement un agent.
Injection de prompt	Instruction malveillante cachée dans un contenu lu par l'IA.
MCP	Model Context Protocol : protocole standard pour brancher des outils sur un agent.
RAG	Génération augmentée par recherche dans une base documentaire.
Risque résiduel	Risque qui subsiste compte tenu des mesures en place.
Shadow AI	Usage d'outils d'IA sans validation de l'organisation.

Annexe C — Avertissement

Ce rapport a été établi à partir d'un questionnaire structuré et des éléments de preuve fournis par l'entité auditée pendant la période d'audit. Il reflète la situation constatée à cette date.

Il ne constitue ni une certification, ni un avis juridique, ni une garantie de sécurité. Les correspondances avec les référentiels (NIST, ISO/IEC, OWASP, CSA, MITRE, réglementation européenne) sont indicatives.

Les marques et noms de référentiels cités appartiennent à leurs détenteurs respectifs et ne signifient aucune approbation de ce rapport.